

-
- Andy K Zhang, Neil Perry, Riya Dulepet, Joey Ji, Celeste Menders, Justin W Lin, Eliot Jones, Gashon Hussein, Samantha Liu, Donovan Julian Jasper, et al. Cybench: A framework for evaluating cybersecurity capabilities and risks of language models. In *The Thirteenth International Conference on Learning Representations*.
- Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent security bench (asb): Formalizing and benchmarking attacks and defenses in llm-based agents. *arXiv preprint arXiv:2410.02644*, 2024.
- Shuyan Zhou, Frank F. Xu, Hao Zhu, Xuhui Zhou, Robert Lo, Abishek Sridhar, Xianyi Cheng, Tianyue Ou, Yonatan Bisk, Daniel Fried, et al. Webarena: A realistic web environment for building autonomous agents. In *Proceedings of the Twelfth International Conference on Learning Representations (ICLR 2024)*, 2024. URL https://proceedings.iclr.cc/paper_files/paper/2024/hash/4410c0711e9154a7a2d26f9b3816d1ef-Abstract-Conference.html.
- Terry Yue Zhuo, Dingmin Wang, Hantian Ding, Varun Kumar, and Zijian Wang. Cyber-zero: Training cybersecurity agents without runtime. *arXiv preprint arXiv:2508.00910*, 2025a.
- Terry Yue Zhuo, Dingmin Wang, Hantian Ding, Varun Kumar, and Zijian Wang. Training language model agents to find vulnerabilities with ctf-doj. *arXiv preprint arXiv:2508.18370*, 2025b.
- Jakub Łucki, Boyi Wei, Yangsibo Huang, Peter Henderson, Florian Tramèr, and Javier Rando. An adversarial perspective on machine unlearning for ai safety. *Transactions on Machine Learning Research*, 2025. URL <https://dblp.org/rec/journals/tmlr/LuckiWH0TR25>. TMLR, published.

Appendix

CONTENTS

A	<i>HackWorld</i>	18
A.1	Tools in <i>HackWorld</i> environment	18
A.2	CTF Challenges in <i>HackWorld</i>	18
B	Experiments	20
B.1	Experimental Settings	20
B.2	Experimental Results	21
B.2.1	Overall Performance	21
B.2.2	Detailed Tool Use Results	35
C	Case Study	36
D	Prompts	41

A HackWorld

A.1 TOOLS IN HackWorld ENVIRONMENT

Table 5 provides a curated inventory of security assessment tools available within the *HackWorld* environment. The catalogue enumerates each instrument alongside its functional description and primary application scenario, encompassing a range of capabilities from reconnaissance and fingerprinting to vulnerability exploitation and evidence documentation.

Table 5: Concise tool catalogue in *HackWorld* environment.

Tool	Description	Primary use / scenario
Burpsuite	Integrated web security testing platform with proxy, repeater, scanner.	Manual and semi-automated penetration testing.
Burp Collaborator	Out-of-band interaction system for blind SSRF/XXE/OOB checks.	Confirming blind and callback-based vulnerabilities.
Cadaver	Command-line WebDAV client.	Test WebDAV enablement and misconfigurations.
CutyCapt	WebKit-based page renderer/screenshot utility.	Evidence capture and reporting.
DAVTest	Automated WebDAV upload/execute assessment.	Quick evaluation of exploitable WebDAV setups.
DirBuster	OWASP GUI directory/file enumerator.	Discover hidden admin panels and sensitive files.
ffuf	Fast Go-based fuzzer with high concurrency.	Directory/parameter fuzzing, rapid discovery.
Gobuster	Lightweight high-performance enumerator (dir, vhost, DNS).	Quick reconnaissance, content and vhost discovery.
netcat (nc)	Classic “Swiss Army knife” networking tool.	Reverse shells, port forwarding, file transfer.
ncat	Modern netcat with SSL/proxy support.	Secure tunneling and forwarding in restricted networks.
Nikto	Baseline web server scanner.	Identify outdated software, misconfigurations.
Skipfish	Active reconnaissance with site mapping.	Asset discovery and vulnerability pre-screening.
SQLMap	Automated SQL injection detection/exploitation.	Database extraction and SQLi exploitation.
Wapiti	Black-box vulnerability scanner.	Automated XSS, SQLi, SSRF and related scans.
WhatWeb	Fingerprinting and technology identification.	CMS/framework/tech stack reconnaissance.
Wfuzz	Flexible fuzzing framework for multiple injection points.	Custom payload testing and parameter fuzzing.
WPScan	WordPress-focused scanner.	Core/plugin/theme vulnerability detection.
ZAP (OWASP)	Open-source proxy and scanner.	Automated scans and CI/CD integration.
Dirb	Classic dictionary-based content scanner.	Quick hidden path/file discovery.

A.2 CTF CHALLENGES IN HackWorld

Table 6 shows all the CTF challenges of the *HackWorld* benchmark, comprising 37 web cybersecurity challenges curated from established sources, including the NYU_ctf_bench, CyBench, and InterCode_CTF.

The majority of challenges, 26 in total, are obtained from *NYU CTF Bench* (Shao et al., 2024), which constitutes the Web subset of the CSAW CTF competition, organized by the NYU OSIRIS Lab. CSAW follows a two-phase structure, comprising a Qualifying Round and a Final Round. We extracted 18 challenges from CSAW-Quals and eight from CSAW-Finals, covering 2013–2023. To ensure traceability, we cross-validated each challenge through official OSIRIS repositories and archival directories, e.g., (CSAW-CTF-2023-Quals, 2023) repository, supplemented with secondary evidence from competition archives such as CTFtime task listings. These materials confirm competition phase, year, and challenge existence, enabling independent verification (CSAW, 2025; CSAW-CTF-2023-Quals, 2023; Shao et al., 2024).

An additional eight challenges were incorporated from Cybench (Zhang et al.), a dataset curated across four recent CTF events: (HackTheBox, 2024), (SekaiCTF, 2022), (SekaiCTF, 2023), (HKCertCTF, 2023), and (GlacierCTF, 2023). Cybench aggregates 40 advanced challenges, each accompanied by task descriptions, starter files, and executable initialization environments. For finer-grained analysis, a portion of these challenges are decomposed into subtasks. From this corpus, we select exclusively Web-related tasks. The selection rationale is based on Cybench’s structural design philosophy, which emphasizes recency, reproducibility, and task decomposition, directly corresponding to our requirements for transparent and verifiable experimentation.

Two additional challenges were sourced from InterCode-CTF (Yang et al., 2023b), a specialized subset of the broader InterCode dataset. InterCode-CTF reconfigures CTF challenges into interactive programming tasks, manually curated from the picoCTF platform. Each task conforms to the structured triplet `<instruction, assets, hidden flag>` and is replayable within a Dockerized Ubuntu/Bash environment. The repository provides task assets and reference solutions, enabling reproducibility. We selected Web-related entries and preserved their original containerized execution model. The inclusion of InterCode-CTF is justified by its acquisition methodology, i.e., manual curation, structured assets, and container-based isolation, and its reliance on picoCTF’s open educational infrastructure, ensuring verifiability and pedagogical relevance.

Table 6: Statistic of Challenges in *HackWorld* Benchmark

ID	Benchmark	Event	Backend Language	Backend Framework
ic-web-16	InterCode_CTF		External	N/A
ic-web-54	InterCode_CTF		External	N/A
cb-gla-web-glacierexchange	cybench	GLA	Python	Flask
cb-hkc-web-22-back-to-the-past	cybench	HKC	Static	Static
cb-hkc-web-05-motp	cybench	HKC	PHP	Native
cb-htb-web-very_easy_flag_command	cybench	HTB	Python	Flask
cb-htb-web-easy_labyrinth_linguist	cybench	HTB	Java	Spring Boot
cb-htb-web-medium_locktalk	cybench	HTB	Python	Flask
cb-s23-web-chunky	cybench	S23	Python	Flask
cb-s23-web-frog-waf	cybench	S23	Java	Spring Boot
2013f-web-historypeats	nyu_ctf_bench	CSAW-Finals	PHP	FuelPHP
2014f-web-webroot	nyu_ctf_bench	CSAW-Finals	PHP	AMFPHP
2016f-web-seizure_cipher	nyu_ctf_bench	CSAW-Finals	Python	Flask
2016f-web-cloudb	nyu_ctf_bench	CSAW-Finals	PHP	Native
2019f-web-biometric	nyu_ctf_bench	CSAW-Finals	Python	Flask
2020f-web-picgram	nyu_ctf_bench	CSAW-Finals	Python	Flask
2023f-web-shreeramquest	nyu_ctf_bench	CSAW-Finals	JavaScript	Express.js
2023f-web-triathlon_or_sprint	nyu_ctf_bench	CSAW-Finals	JavaScript	Express.js
2013q-web-guess_harder	nyu_ctf_bench	CSAW-Quals	PHP	Native
2014q-web-silkgoat	nyu_ctf_bench	CSAW-Quals	Python	Flask
2015q-web-k_stairs	nyu_ctf_bench	CSAW-Quals	Python	Flask
2015q-web-throwback	nyu_ctf_bench	CSAW-Quals	Python	Flask
2016q-web-i_got_id	nyu_ctf_bench	CSAW-Quals	Perl	Native
2016q-web-mfw	nyu_ctf_bench	CSAW-Quals	PHP	Native
2017q-web-littlequery	nyu_ctf_bench	CSAW-Quals	PHP	Native
2017q-web-notmycupofcoffe	nyu_ctf_bench	CSAW-Quals	Java	JSP
2017q-web-orange	nyu_ctf_bench	CSAW-Quals	JavaScript	Express.js
2017q-web-orangepv2	nyu_ctf_bench	CSAW-Quals	JavaScript	Express.js
2021q-web-gatekeeping	nyu_ctf_bench	CSAW-Quals	Python	Flask
2021q-web-no_pass_needed	nyu_ctf_bench	CSAW-Quals	JavaScript	Express.js
2021q-web-poem_collection	nyu_ctf_bench	CSAW-Quals	PHP	Native
2021q-web-securinotes	nyu_ctf_bench	CSAW-Quals	JavaScript	Meteor.js
2023q-web-cookie_injection	nyu_ctf_bench	CSAW-Quals	Python	Flask
2023q-web-philanthropy	nyu_ctf_bench	CSAW-Quals	Python	Flask
2023q-web-rainbow_notes	nyu_ctf_bench	CSAW-Quals	JavaScript	Express.js
2023q-web-smug_dino	nyu_ctf_bench	CSAW-Quals	JavaScript	Express.js

B EXPERIMENTS

B.1 EXPERIMENTAL SETTINGS

Backbones. We employ two types of backbones to construct computer-using agents, including four proprietary models and one open-source GUI action model. Details are as follows:

- *Claude-3.5-Sonnet*: A mid-sized proprietary LLM developed by Anthropic, optimized for reasoning and code understanding. It serves as a strong baseline for multi-step reasoning tasks.
- *Claude-3.7-Sonnet*: An enhanced version of Claude-3.5, incorporating improved context handling and reasoning strategies. Empirically, it achieves the best overall performance among all tested backbones.